

AI Governance & Security Checklist

A practical checklist for deploying Microsoft Copilot and AI agents in a Nordic, regulated organisation, built around NIS2, GDPR and the EU AI Act. Every item includes why it matters and how to do it.

1. Data & access

☐ **Classify the data your AI and agents can reach**

Why: Copilot inherits every permission a user already has, so if access is too broad, so are the answers.

How: Run a sensitivity-label review in Microsoft Purview and tag content public / internal / confidential. Auto-label where you can, and start with the sites holding personal or business-critical data.

☐ **Apply least privilege to every agent**

Why: An over-permissioned agent is a single point of large-scale exposure.

How: Scope each agent to specific SharePoint sites and data sources. Avoid tenant-wide access by default, and check the group membership behind any “everyone” access.

☐ **Fix oversharing before any rollout**

Why: Copilot surfaces existing oversharing instantly and at scale.

How: Use SharePoint Advanced Management and Restricted Content Discovery to find broadly-shared or “anyone” links, and tighten them before go-live.

☐ **Extend DLP to AI prompts and outputs**

Why: Sensitive data can leak through a prompt as easily as through email.

How: Enable Microsoft Purview DLP for Microsoft 365 Copilot, plus endpoint DLP to block confidential content from being pasted into prompts.

2. Identity & ownership

☐ **Give every agent an owner and an identity**

Why: You cannot govern what no one owns, and NIS2 expects clear accountability.

How: Assign a named business owner and a service identity (Entra Agent ID) to each agent, and record both in a simple agent register.

☐ **Require MFA and Conditional Access for AI tools**

Why: AI tools reach your most valuable data, so they deserve your strongest access controls.

How: Enforce MFA and compliant-device checks via Entra Conditional Access for Copilot, Copilot Studio and Azure AI Foundry.

☐ **Decide tenant-wide vs scoped publishing**

Why: A quiet pilot limits the blast radius if something is misconfigured.

How: Publish to a pilot group first, and promote tenant-wide only after a security and accuracy review.

3. Data residency & compliance

☐ **Confirm the EU Data Boundary covers the services you use**

Why: Data residency is a recurring requirement for Nordic public sector and regulated industries.

How: Check EU Data Boundary scope per service and model. Some processing or model availability may still route outside the EU, so document any exceptions.

☐ **Check model and region availability against your requirements**

Why: The model you want may not be available in an EU region yet.

How: Confirm region availability before committing, and pin workloads to EU regions where residency is required.

☐ **Map your obligations: GDPR, NIS2 and the EU AI Act**

Why: These now apply directly to how you build and run AI, with real penalties.

How: List which agents touch personal or critical data, classify each use case by EU AI Act risk level, and map each to its duties. NIS2 adds governance, risk-management and incident-reporting expectations.

☐ **Keep an audit trail of AI usage**

Why: Logging is both a security control and a compliance requirement.

How: Enable Purview Audit and activity logs for Copilot and agents, and retain them per your policy and sector rules.

4. Shadow AI

☐ **Set a policy on personal AI accounts and unsanctioned tools**

Why: Most AI risk today enters through tools you never approved.

How: Publish a short, plain-language acceptable-use policy stating what is and isn't allowed, and why.

☐ **Inventory the AI tools and agents already in use**

Why: You can only govern what you can see.

How: Discover usage via Microsoft Defender for Cloud Apps or network logs, and keep a living inventory.

☐ **Offer sanctioned alternatives people actually want**

Why: People reach for shadow tools when the approved option is worse.

How: Provide a good, approved tool for the top use cases so staff have no reason to go elsewhere.

5. Accuracy & lifecycle

☐ **Add evaluation and guardrails for accuracy**

Why: The EU AI Act and your users both expect outputs you can trust.

How: Build an evaluation set of real questions, and add groundedness checks and content filters in Azure AI Foundry. Re-run them whenever a model changes.

☐ **Keep a human in the loop for high-risk outputs**

Why: High-risk decisions need accountable human judgement.

How: Require human review for finance, legal, HR and customer-facing outputs.

☐ **Have an incident and rollback plan**

Why: NIS2 expects you to detect, respond and report, and speed matters.

How: Define how to disable an agent fast, who decides, and how you report. Then test it before you need it.

☐ **Review agents and permissions on a schedule**

Why: Access and use cases drift over time.

How: Re-review agents, access and prompts quarterly, and retire what is unused.

Need help putting this in place?

NetNordic helps Nordic organisations deploy, secure and govern Microsoft AI in line with NIS2, GDPR and the EU AI Act.
sales.se@netnordic.com · +46 8 555 068 00